Политика за защита от фишинг и зловредни прикачени файлове

Фирма	MediaPrint House OOD
Тема и префикс на кодовете	Защита от фишинг и зловредни прикачени файлове, PHI
Версия	0.1 (чернова)
Дата	28.10.2026
Автор	Ръководител ИТ
Одобрил	Управител
Следващ преглед	28.10.2027

1. Цел

Журналист (A-17) отваря зловреден прикачен файл от пощата (A-14) и нападател получава контрол над станцията му (A-13) и достъп до CMS (A-01). Това е най-високият неприемлив риск в регистъра (риск 20, критичен).

Адресирани рискове (R-ID)	R-01

2. Обхват

Политиката важи за	Пощата (A-14), работните станции на журналистите (A-13), журналистите и редакторите (A-17)
Извън обхвата	Не влизат сървърите в Пазарджик (A-06) и Ловеч (A-08), публичният сайт (A-05) и личните устройства на служителите.

3. Роли и отговорности

Роля (длъжност)	Отговорност
Системен администратор	Прилага контролите: настройва филтъра на пощата и станциите
Ръководител ИТ	Одобрява, включително изключенията.
Управител	Проверява отчетите и резултатите от тестовете.
Журналисти и редактори	Спазват политиката и докладват съмнителни писма.

4. Контроли

Контрол 1

Код	PHI-01
Контрол	Блокиране на опасни прикачени файлове
Изискване	Пощата (A-14) задържа в карантина входящи писма с прикачени .exe, .lnk, .js, .iso и Office файлове с макроси от външни податели.
Отговорник	Системен администратор - настройва филтъра.

Честота	Автоматично за всяко писмо; проверка веднъж месечно.
Проверка	Месечен отчет за задържаните писма. Тест: изпраща се тестов .lnk файл отвън - трябва да остане в карантина.
Доказателство	Лог на пощата в Wazuh (A-15), 90 дни.
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 2

Код	PHI-02
Контрол	Блокиране на макроси
Изискване	На 100% от станциите (A-13) макросите във файлове от интернет са забранени.
Отговорник	Системен администратор - прилага настройката на всяка станция.
Честота	Постоянно; проверка веднъж месечно.
Проверка	Месечен отчет от Wazuh (цел: 100% от станциите). Тест: отваря се тестов файл с макрос - макросът не трябва да се стартира.
Доказателство	Отчет в Wazuh (A-15), 12 месеца.
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 3

Код	PHI-03
Контрол	Алерт при подозрително поведение
Изискване	Wazuh вдига алерт, когато Word или Excel на станция (A-13) стартира PowerShell или cmd. Алертът се разглежда до 1 час.
Отговорник	Системен администратор - разглежда алертите.
Честота	Автоматично; проверка веднъж на 3 месеца.
Проверка	Тест веднъж на 3 месеца: документ стартира PowerShell - алертът трябва да се появи до 5 минути.
Доказателство	Алерти в Wazuh, 12 месеца.
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 4

Код	PHI-04
Контрол	Обучение и тестов фишинг
Изискване	Всеки служител (A-17) минава обучение до 5 работни дни след постъпване и веднъж годишно. Веднъж на 3 месеца се праща тестово фишинг писмо. Цел: под 10% кликнали.
Отговорник	Ръководител ИТ - организира обучението и тестовете.
Честота	Обучение - веднъж годишно; тест - веднъж на 3 месеца.

Проверка	Отчет след всеки тест: % кликнали (цел: под 10%).
Доказателство	Присъствен списък и отчети от тестовете, 24 месеца.
Annex A	*попълва се в Час 6*
R-ID	R-01

Контрол 5

Код	PHI-05
Контрол	Докладване и изолиране
Изискване	Служителят (A-17) докладва съмнително писмо до 15 минути. Системният администратор изолира станцията (A-13) от мрежата и сменя паролата до 30 минути.
Отговорник	Служителят - докладва. Системен администратор - изолира станцията.
Честота	При всеки сигнал; учение веднъж на 6 месеца.
Проверка	Учение веднъж на 6 месеца: тестов сигнал - станцията трябва да е изолирана до 30 минути.
Доказателство	Тикет с часа на сигнала и изолирането, 12 месеца.
Annex A	*попълва се в Час 6*
R-ID	R-01

5. Изключения

Одобрява	Ръководител ИТ
Максимален срок	30 дни
Записват се в	Регистър на изключенията в тикет системата

6. Мерки при неспазване

Нарушение на политиката се записва като инцидент. При повторно нарушение Управителят решава за дисциплинарни мерки.

7. Преглед

Преглежда	Управител
Период	12 месеца (28.10.2027) и след всеки фишинг инцидент

Самопроверка преди качване в git (чеклист 6.2, т. 1 до 10)

№	Проверка	Да / Не
1	Политиката сочи R-ID от регистъра на риска	Да
2	Обхватът казва и какво НЕ влиза	Да
3	Ролите са длъжности; прилагащият и проверяващият са различни	Да
4	Има поне пет разписани контрола	Да
5	Има конкретни стойности там, където е нужно число	Да

№	Проверка	Да / Не
6	Нито една забранена формулировка: редовно, периодично, по подходящ начин, при нужда, своевременно, адекватно	Да
7	Всеки контрол има начин на проверка	Да
8	Всеки контрол посочва какво доказателство остава при работата му.	Да
9	Има механизъм за изключения със срок и одобряващ	Да
10	Има дата на следващ преглед	Да